

Proyecto de Propuesta de prevención de pentesting

Índice

1. Introducción
2. Metodología
3. Fases del pentesting
 - 3.1 Reconocimiento
 - 3.2 Enumeración
 - 3.3 Explotación
4. Vulnerabilidades detectadas
5. Flags obtenidas
6. Propuesta de prevención
7. Propuesta de mitigación
8. Impacto potencial
9. Conclusión

Introducción

El objetivo de este pentesting ha sido analizar el nivel de seguridad de una máquina y aplicaciones vulnerables, identificando posibles fallos de seguridad y comprobando hasta qué punto pueden ser explotados por un atacante. Para ello, se han realizado diferentes pruebas de reconocimiento, enumeración y explotación sobre una máquina Metasploitable y una aplicación web vulnerable.

El alcance del ejercicio se ha centrado en detectar vulnerabilidades conocidas, explotar aquellas que fuesen viables y analizar las consecuencias que tendría este tipo de ataques en un entorno real, tanto a nivel de sistema como de aplicaciones web.

Metodología

La metodología seguida se basa en un enfoque clásico de pentesting, estructurado en varias fases bien definidas. En primer lugar, se realizó un reconocimiento inicial del sistema para identificar servicios activos y posibles puntos de entrada. Posteriormente, se llevó a cabo una fase de enumeración más detallada para obtener información concreta sobre versiones y configuraciones vulnerables.

Finalmente, se pasó a la fase de explotación, donde se utilizaron herramientas especializadas para comprobar si las vulnerabilidades detectadas podían ser aprovechadas con éxito. Entre las principales herramientas empleadas se encuentran Nmap, Metasploit, msfvenom, Netcat, Kali Linux, Apache Tomcat y DVWA.

Fases del pentesting

Reconocimiento

Durante la fase de reconocimiento se identificó la dirección IP de la máquina objetivo y se realizaron escaneos básicos para detectar puertos abiertos y servicios activos. Para ello se utilizó la herramienta Nmap, lo que permitió obtener una visión general del sistema y sus servicios expuestos.

Enumeración

En la fase de enumeración se profundizó en el análisis de los servicios detectados, obteniendo información detallada sobre versiones de software, sistema operativo y configuraciones. Se identificaron servicios obsoletos y configuraciones inseguras que posteriormente serían explotadas.

Explotación

En la fase de explotación se utilizaron herramientas como Metasploit y msfvenom para aprovechar las vulnerabilidades detectadas. Se logró acceso remoto al sistema, ejecución de comandos y escalada de privilegios hasta obtener permisos de administrador, demostrando el impacto real de los fallos de seguridad encontrados.

Vulnerabilidades detectadas

Durante el análisis se detectaron múltiples vulnerabilidades en distintos servicios:

- **FTP (vsftpd 2.3.4)**: versión vulnerable que incluye una puerta trasera que permite el acceso remoto bajo determinadas condiciones.
- **SSH (OpenSSH)**: versión antigua susceptible a ataques de fuerza bruta y posibles exploits conocidos.
- **SMTP (Postfix)**: posibilidad de enumeración de usuarios mediante técnicas de fuzzing.
- **HTTP (Apache 2.2.8)**: vulnerable a ataques como directory traversal y XSS.
- **Samba 3.X**: vulnerable a ejecución remota de comandos mediante exploits conocidos.
- **MySQL y PostgreSQL**: servicios expuestos con configuraciones inseguras y posibles credenciales por defecto.
- **Apache Tomcat**: acceso al panel de administración mediante credenciales por defecto.
- **DVWA**: vulnerable a inyección de comandos, permitiendo ejecución remota en el sistema.

Estas vulnerabilidades fueron confirmadas mediante escaneos y pruebas prácticas durante la explotación.

Flags obtenidas

Durante la fase de explotación se obtuvieron diferentes evidencias que confirman el acceso no autorizado al sistema:

- Acceso remoto a la máquina Metasploitable mediante exploits de Metasploit.
- Obtención de una reverse shell a través de Apache Tomcat utilizando un payload generado con msfvenom.
- Escalada de privilegios hasta el usuario root, permitiendo la ejecución de comandos críticos como el apagado del sistema.

- Ejecución de comandos en DVWA mediante inyección, obteniendo acceso a información sensible como el archivo: `/etc/passwd`.

Estas flags demuestran que el sistema puede ser comprometido de forma completa.

Propuesta de prevención

Para reducir riesgos futuros, se recomienda establecer una política clara de actualización y mantenimiento de los sistemas y servicios. Mantener el software actualizado evita que vulnerabilidades conocidas puedan ser explotadas fácilmente.

También es importante deshabilitar servicios innecesarios y aplicar configuraciones seguras desde el primer momento, eliminando credenciales por defecto y restringiendo accesos a servicios sensibles. La segmentación de red y el uso de firewalls ayudan a limitar la exposición del sistema.

Por último, la formación en seguridad de los administradores resulta clave para evitar errores de configuración y mejorar la postura de seguridad general del sistema.

Propuesta de mitigación

Como medidas de mitigación, se recomienda actualizar o sustituir inmediatamente los servicios vulnerables detectados durante el pentesting. Además, se deben reforzar las configuraciones de servicios críticos como SSH, FTP y bases de datos, limitando accesos y permisos.

En las aplicaciones web, es necesario implementar controles de validación de entradas para evitar ataques de inyección y otras vulnerabilidades comunes. Asimismo, se debe aplicar el principio de mínimo privilegio para evitar escaladas de permisos innecesarias.

La implantación de sistemas de monitorización y detección de intrusiones permitiría identificar ataques de forma temprana y reducir su impacto.

Impacto potencial

La aplicación de las medidas propuestas tendría un impacto muy positivo en la seguridad del sistema. Reduciría notablemente la superficie de ataque, dificultaría la explotación de vulnerabilidades y limitaría las consecuencias de un posible compromiso.

Un sistema actualizado y bien configurado no solo mejora la seguridad técnica, sino que también incrementa la estabilidad del entorno y la confianza en su uso, especialmente en escenarios reales de producción.

Conclusión

Este pentesting demuestra que un sistema desactualizado o mal configurado puede ser comprometido con relativa facilidad utilizando herramientas y técnicas ampliamente conocidas. La práctica pone de manifiesto la importancia de aplicar medidas de seguridad de forma continua y no puntual.

La seguridad informática debe entenderse como un proceso constante de revisión, actualización y mejora. Solo mediante una gestión activa de la seguridad es posible reducir riesgos y proteger de forma efectiva los sistemas frente a posibles ataques.